

Tools and Programming

CHAPTER 12

12.01 - Pen Testing Toolbox

Episode **Pen Testing Toolbox**
title:

Objective: **5.3 Explain use cases of the following tools during the phases of a penetration test**

RECONNAISSANCE

- **For reconnaissance, use:**

- Nmap
- Whois
- Nslookup
- Theharvester
- Shodan
- Recon-NG
- Censys
- Aircrack-NG
- Kismet
- WiFite
- SET
- Wireshark
- Hping
- Metasploit framework

ENUMERATION

- **To list targets, use:**
 - Nmap
 - Nslookup
 - Wireshark
 - Hping

VULNERABILITY SCANNING

- **To scan for vulnerabilities, use:**
 - Nmap
 - Nikto
 - OpenVAS
 - SQLmap
 - Nessus
 - W3AF
 - OWASP ZAP
 - Metasploit framework

CREDENTIAL ATTACKS

- **For offline password cracking, use:**
 - Hashcat
 - John the Ripper
 - Cain and Abel
 - Mimikatz
 - Aircrack-NG

CREDENTIAL ATTACKS

- **For brute-forcing services, use:**
 - SQLmap
 - Medusa
 - Hydra
 - Cain and Abel
 - Mimikatz
 - Patator
 - W3AF
 - Aircrack-NG

PERSISTENCE

- **Once you have exploited a target, use these to make sure you can get back in:**
 - SET
 - BeEF
 - SSH
 - NCAT
 - NETCAT
 - Drozer
 - Powersploit
 - Empire
 - Metasploit framework

CONFIGURATION COMPLIANCE

- **To evaluate a configuration to determine if it's compliant with a standard or regulation, use:**
 - Nmap
 - Nikto
 - OpenVAS
 - SQLmap
 - Nessus

EVASION

- **To evade detection, use:**
 - SET
 - Proxychains
 - Metasploit framework

DECOMPILATION

- **To decompile executables, use:**
 - Immunity debugger
 - APKX
 - APK studio

PENETRATION TESTING USE CASES

- **Forensics**

- To carry out digital forensics, use:
 - Immunity debugger

- **Debugging**

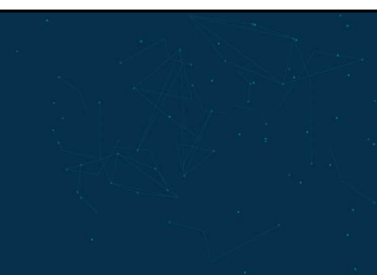
- To debug code, use:
 - OLLYDBG
 - Immunity debugger
 - GDB
 - WinDBG
 - IDA

SOFTWARE ASSURANCE

- **For general software assurance, use:**
 - Findsecbugs
 - SonarQube
 - YASCA
- **For fuzzing, use:**
 - Peach
 - AFL

PENETRATION TESTING USE CASES

- **Forensics – Immunity debugger**
- **Debugging – OLLYDBG, Immunity debugger, GDB, WinDBG, IDA**
- **Software assurance – Findsecbugs, SonarQube, YASCA**
 - Fuzzing – Peach, AFL
 - Static Application Security Testing (SAST)
 - Dynamic Application Security Testing (DAST)



New Episode

12.02

Episode title: **More Pen Testing Toolbox Tools**

Objective: **2.4.5, 2.4.9, 2.4.10, 2.4.11, 2.4.15, 2.4.16, 3.1.3.7, 3.1.3.7, 3.1.3.9**

SPIDERFOOT

- Open-source tool
- Automates OSINT
- Uncovers IPs, domains, emails

HUNTER.IO

- Finds emails addresses
- Uses public data
- Confidence scores

DNS DUMPSTER

- Free DNS recon tool
- Maps subdomains, records
- Visualizes infrastructure

A MASS

- Subdomain enumeration
- Combines OSINT, brute force
- Maps attack surface

INSIDER

- Wi-Fi discovery tool
- Scans wireless networks
- Finds misconfigured points

[OSINTFRAMEWORK.COM](https://osintframework.com)

- Director of tools
- Organized by categories
- Launchpad for Recon

GRYPE

- Vulnerability scanner
- Analyzes packages, BOMs
- Matches known CVEs

TRIVY

- Security scanner
- Checks containers, code
- Ideal for DevOps

CUBE HUNTER

- Kubernetes tool
- Scan clusters
- Identifies risks

12.03 - Using Kali Linux

Episode **Using Kali Linux**
title:

Objective: **5.3 Explain use cases of the following tools during the phases of a penetration test**

KALI LINUX DEMO

- **Kali Linux demo**

12.04 - Scanners and Credential Tools

Episode title: **Scanners and Credential Tools**

Objective: **5.3 Explain use cases of the following tools during the phases of a penetration test**

SCANNERS

Tool	Notes	URL
Nikto	Web server vulnerability scanner	https://github.com/sullo/nikto
OpenVAS (Open Vulnerability Assessment System)	Open Source vulnerability scanner and manager	https://www.openvas.org/
SQLmap (Structured Query Language)	Automatic SQL injection and database takeover tool	https://sqlmap.org/
Nessus	Commercial vulnerability scanner (free for non-professional use)	https://www.tenable.com/products/nessus/nessus-professional

CREDENTIAL TESTING TOOLS

Tool	Category	Notes	URL
Hashcat	Offline	Advanced password recovery (world's fastest)	https://hashcat.net/hashcat/
Medusa	Online	Parallel network login auditor	https://www.kali.org/tools/medusa/
Hydra	Online	Parallelized login cracker	https://sectools.org/tool/hydra/
Cewl		Custom wordlist generator	https://digi.ninja/projects/cewl.php
John the Ripper	Offline	Password cracker	https://www.openwall.com/john/

CREDENTIAL TESTING TOOLS, CONT'D

Tool	Category	Notes	URL
Mimikatz	Online/offline	A little tool to play with Windows security	https://github.com/gentilkiwi/mimikatz
Patator	Online	Multi-purpose brute-forcer	https://github.com/lanjelot/patator
W3AF	Online	Web Application Attack and Audit framework	https://sourceforge.net/projects/w3af/

DH1

Slide 30

DH1

broken url

Damon Hinton, 2025-08-08T23:29:50.430

MS1 0

<https://sourceforge.net/projects/w3af/>

Michael Solomon, 2025-08-11T18:47:36.529

Analyze tool output

- **Password cracking – demo John the Ripper**

Analyze tool output

- **Pass the hash – demo Mimikatz**

12.05 – Open-Source Research Tools

Episode title: **Open-Source Research Tools**

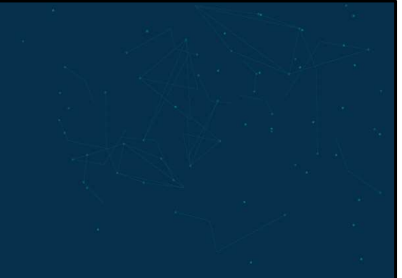
Objective: **5.3 Explain use cases of the following tools during the phases of a penetration test**

OPEN-SOURCE INTELLIGENCE (OSINT) TOOLS

Tool	Notes	URL
Whois	Domain details (contacts, name servers, etc.)	https://whois.icann.org/en (and many more)
Nslookup	DNS information	Installed or available on most OSs
FOCA	Fingerprint Organizations with Collected Archives – finds document metadata	https://github.com/ElevenPaths/FOCA
Theharvester	Gathers info from many sources (email, hosts, open ports, etc.)	https://github.com/laramies/theHarvester
Shodan	Finds Internet connected devices	https://www.shodan.io/
Maltego	Data mining for investigations	https://www.paterva.com/web7/buy/maltego-clients/maltego-ce.php
Recon-NG	Web reconnaissance	https://github.com/lanmaster53/recon-ng
Censys	Finds Internet connected devices	https://censys.io/

ANALYZE TOOL OUTPUT

- Whois demo
- Nslookup demo



12.06 – Wireless and Web Pen Testing Tools

Episode title: **Wireless and Web Pen Testing Tools**

Objective: **5.3 Explain use cases of the following tools during the phases of a penetration test**

WIRELESS TOOLS

Tool	Notes	URL
Aircrack-NG	Monitoring, attacking, testing, cracking	https://www.aircrack-ng.org/
Kismet	Wireless detector, sniffer and intrusion detection system	https://www.kismetwireless.net/
WiFite	Wrapper for other wireless tools (current version is WiFite2)	https://github.com/derv82/wifite2

WEB PROXIES AND SOCIAL ENGINEERING TOOLS

Web proxies

Tool	Notes	URL
OWASP ZAP	Zed Attack Proxy – Web application security scanner	https://www.zaproxy.org/
Burp Suite	Graphical tool for testing web application security	https://portswigger.net/burp

Social engineering tools

Tool	Notes	URL
SET	Social Engineering Toolkit – penetration testing using social engineering	https://www.trustedsec.com/social-engineer-toolkit-set/
BeEF	Browser Exploitation Framework – focus is on web browser	http://beefproject.com/

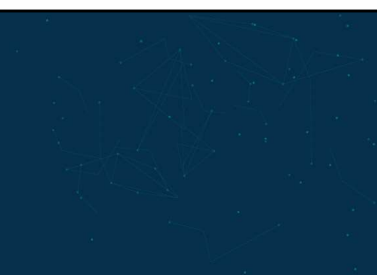
WEB PROXIES AND SOCIAL ENGINEERING TOOLS

Web proxies

Tool	Notes	URL
OWASP ZAP	Zed Attack Proxy – Web application security scanner	https://www.zaproxy.org/
Burp Suite	Graphical tool for testing web application security	https://portswigger.net/burp

ANALYZE TOOL OUTPUT

- **Proxying a connection - demo**



12.07

Episode **More Wireless and Web Pen**
title: **Testing Tools**

Objective: **4.9.2.1, 4.9.2.2, 4.9.2.4, 4.9.2.8**

NEWADDITIONS

- Scapy
- TCP Relay
- Mob SF
- Blue Strike

SCAPY

- Python-based
- Sends and analyzes custom packets
- Fuzz, spoof, scan, and test proprietary protocols
- Flexible
- Runs interactively
- Favorite among advanced testers

TCP RELAY

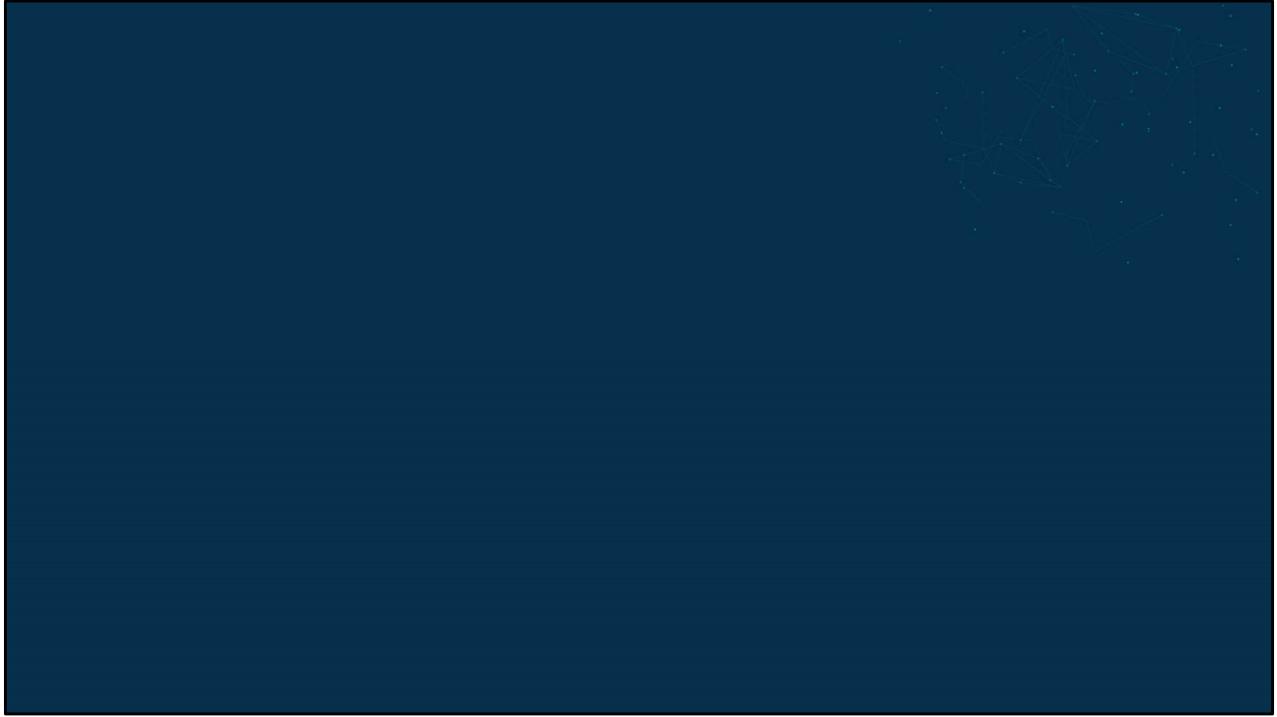
- **Replay pcap files**
- **Simulate realistic traffic**
- **Uses:**
 - Test intrusion detection systems
 - Verify network response
 - Asses protocol handling

MOB SF

- **Mobile security framework (MOB SF)**
- **Test Android and iOS apps**
- **Supports static and dynamic analysis**
 - Scan vulnerabilities
 - Hard coded secrets
 - Excessive permissions
 - Insecure API storage

BLUE STRIKE

- **Bluetooth attacks**
 - Bluetooth Low Energy (BLE) devices
- **Identify vulnerabilities**
- **Pairing procedures**
- **Service discovery**
- **Inject malicious code packets**
- **Good for:**
 - Testing wearables
 - Medical devices | IoT sensors



12.08

Episode **Remote Access Tools**
title:

Objective: **5.3 Explain use cases of the following tools during the phases of a penetration test**

REMOTE ACCESS TOOLS

Tool	Notes	URL
SSH	Secure shell	Included or available in most OSs
NCAT	Similar to nc, but from Nmap developers	https://nmap.org/ncat/
NETCAT	Same as nc	Included or available in most OSs
Proxychains	Forces TCP connections through a proxy	https://github.com/haad/proxychains

ANALYZE TOOL OUTPUT

- **Setting up a bind shell - demo**

ANALYZE TOOL OUTPUT

- **Getting a reverse shell - demo**

12.09

Episode title: **Analyzers and Mobile Pen Testing Tools**

Objective: **5.3 Explain use cases of the following tools during the phases of a penetration test**

NETWORKING AND MOBILE TOOLS

Networking

Tool	Notes	URL
Wireshark	Packet sniffer/protocol analyzer	https://www.wireshark.org/
Hping	Packet assembler/analyzer	https://www.hping.org/

Mobile Tools

Tool	Notes	URL
Drozer	Android security and attack framework	https://labs.withsecure.com/tools/drozer
APKX	Android APK decompiler	https://github.com/b-mueller/apkx
APK Studio	Android app decompiler	https://vaibhavpandey.com/apkstudio

12.10

Episode **Other Pen Testing Tools**
title:

Objective: **5.3 Explain use cases of the following tools during the phases of a penetration test**

MISCELLANEOUS TOOLS

Tool	Notes	URL
Searchsploit	Search tool for exploit database	https://www.exploit-db.com/searchsploit/
Powersploit	Post-exploitation framework (MS PowerShell)	https://github.com/PowerShellMafia/PowerSploit
Responder	Microsoft network poisoner	https://github.com/SpiderLabs/Responder
Impacket	Python classes for working with network protocols	https://github.com/CoreSecurity/impacket
Empire	PowerShell/Python post-exploitation agent	https://github.com/EmpireProject/Empire
Metasploit framework	Comprehensive penetration testing framework	https://www.metasploit.com/

12.11

Episode **Even More Pen Testing Tools**
title:

Objective: **5.2.7.1, 5.2.7.4, 5.2.7.6, 5.2.7.9, 5.2.7.11**

LATERAL MOVEMENT TOOLS

- **Windows environment**
- **Pivot systems**
- **Remote access**
- **Automated scripting**

LOL BINS

- **Living-off-the-land (LOL)**
- **Legitimate executables**
- **Avoid detection**
- **Built-in tools**
- **Stealthy post-exploitation**

MPACKET FRAMEWORK

- **Python scripts**
- **Network protocols**
- **Extract credentials**
- **Remote
command execution**

SSHUTTEL

- **Creates a transparent proxy server or SSH Tunnel**
- **Access internal resources**
- **TCP/UDP and DNS**
- **Minimal setup**

BATCH FILES

- Automate commands
- Deploy tasks
- Gather system info
- Hide in plain sight

PS EXEC

- **Remote commands**
- **Valid credentials**
- **Lateral movement**
- **Remote admin access**

12.12

Episode title: **Labtainers Lab (Metasploit Framework)**

Objective: **5.3 Explain use cases of the following tools during the phases of a penetration test**

Lab Software Vulnerabilities: metasploit

- **Intro lab (Metasploit framework)**
- **Lab requires download and setup time**
 - All automatic

12.13

Episode title: **Labtainers Lab (Wireshark Packet Inspection)**

Objective: **5.3 Explain use cases of the following tools during the phases of a penetration test**

Lab Network Traffic Analysis: packet-introspection

- **Intro lab (Using Wireshark for more advanced packet analysis)**

12.14

Episode **Labtainers Lab (SSH)**
title:

Objective: **5.3 Explain use cases of the following tools during the phases of a penetration test**

Lab Crypto Labs: sshlab

- **Intro lab (Secure remote access with SSH)**

12.15

Episode title: **Scanners, Debuggers, and Wireless Tools**

Objective: **5.3 Explain use cases of the following tools during the phases of a penetration test**

SCANNERS

- **Tools that carry out active reconnaissance**
- **Wapiti**
 - <https://wapiti-scanner.github.io/>
- **WPScan**
 - <https://github.com/wpscanteam/wpscan>
- **Brakeman**
 - <https://brakemanscanner.org/>
- **Scout Suite**
 - <https://github.com/nccgroup/ScoutSuite>

SCANNERS

- **Tools that carry out active reconnaissance**

DEBUGGERS

- **Covenant**
 - <https://github.com/cobbr/Covenant>

WIRELESS

- **EAPHammer**
 - <https://github.com/s0lst1c3/eaphammer>
- **MDK4**
 - <https://github.com/aircrack-ng/mdk4>
- **Spooftooph**
 - <https://www.kali.org/tools/spooftooph/>

WIRELESS

- **Reaver**
 - <https://www.kali.org/tools/reaver/>
- **Wireless Geographic Logging Engine (WiGLE)**
 - <https://www.wigle.net/>
- **Fern-Wifi-Cracker**
 - <https://www.kali.org/tools/fern-wifi-cracker/>

12.16

Episode title: **More Scanners, Debuggers, and Wireless Tools**

Objective: **5.3 Explain use cases of the following tools during the phases of a penetration test**

MODERN INFRASTRUCTURE

- On-premise and cloud
- Tools for cloud
- Containers, Kubernetes

DOCKER BENCH FOR SECURITY

- **Scan Docker**
- **Identifies risks**
- **CIS Benchmark**
- **Can highlight issues with:**
 - Privilege
 - Networking
 - Image usage

CUBE HUNTER

- **Scan Kubernetes**
- **Finds vulnerabilities**
- **Looks for common mistakes:**
 - Unauthenticated dashboards
 - Overly permissive role bindings
 - Exposed services
- **Run within the cluster**
 - Mimic inside threats
- **Run outside the cluster**
 - Simulate outside threats

PROWLER

- **Command-line tool**
- **Asses security posture in AWS**
- **Checks for:**
 - Insecure policies
 - Open S3 buckets
 - Misconfigured IAM roles
- **Maps findings to compliance standards**
 - CIS, HIPAA, GDPR

CLOUD NATIVE TOOLS

- AWS Inspector
- Azure Security Center
- Google Security Command Center
- Vulnerability detection

12.17

Episode title: **Web, Steganography, and Cloud Tools**

Objective: **5.3 Explain use cases of the following tools during the phases of a penetration test**

WEB APPLICATION TOOLS

- **No pen testing toolbox would be complete without web application and other miscellaneous tools**
- **Gobuster**
 - <https://www.kali.org/tools/gobuster/>

MISC. TOOLS

- **mitm6**
 - <https://github.com/dirkjanm/mitm6>
- **CrackMapExec**
 - <https://github.com/byt3bl33d3r/CrackMapExec>
- **TruffleHog**
 - <https://github.com/trufflesecurity/trufflehog>

STEGANOGRAPHY TOOLS

- **Open stego**
 - <https://www.openstego.com/>
- **Steghide**
 - <https://www.kali.org/tools/steghide/>
- **Snow**
 - <https://github.com/mattkwan-zz/snow>
- **Coagula**
 - <https://www.abc.se/~re/Coagula/Coagula.html>

STEGANOGRAPHY TOOLS

- **Sonic Visualizer**
 - <https://www.sonicvisualiser.org/>
- **TinEye**
 - <https://tineye.com/>
- **Metagoofil**
 - <https://www.kali.org/tools/metagoofil/>
- **Online SSL checkers**
 - <https://www.sslshopper.com/ssl-checker.html>
 - <https://www.sslchecker.com/sslchecker>

CLOUD TOOLS

- **CloudBrute**
 - <https://www.kali.org/tools/cloudbrute/>
- **Pacu**
 - <https://github.com/RhinoSecurityLabs/pacu>
- **Cloud Custodian**
 - <https://github.com/cloud-custodian/cloud-custodian>

DEPRECATED TOOLS

- **Tools come and go as technology changes**
- **There are currently at least 3 deprecated tools on the exam**
 - Cain and Abel (Cain)
 - DirBuster
 - OllyDbg
- **Why are they still on the exam?**
 - Part of the historical landscape
 - Lots of tutorials, books, and articles include them